Role Assistants
独立精査レポート

対象：Hoa Chau Phuoc氏 / Meta Global AI Developer Hackathon向け公開プロジェクト

> 判定：主要なデモ経路は動作。中核の安全性説明には、重要な修正が3点あります。
> 署名付き承認は実装されています。ただし、企業への紐付け、元データへの拘束、禁止スキルの実行制御が十分ではありません。

企画としては、従業員が使うAI支援と会社のルールを両立させる目的が明確です。役割ごとの導線、テンプレートへの切替表示、Private障害時に標準モデルへ切り替えない設計、計測の限界を記す姿勢は評価できます。一方、「計算はコード」「結果は署名済み」だけでは、正しい注文と正しい企業の権限に基づく処理を保証できません。

確認項目	今回の結果
既存テストの再実行	Python 403 / 403、JavaScript 33 / 33が成功。FAKE_AI=1で外部モデル呼出しなし。
公開デモの通し確認	架空の物流企業 → Wonder組織図 → Sparkアシスタント → Sales招待 → 3段階承認 → 注文完了。FinanceにGlimmer応答の表示。
独立した異常系検証	別企業の計画の受理、注文と異なる有効引数の計算、禁止スキルの実行、旧計画の承認継続をローカル再現。
計測値の確認	計測コード・ケース構成と説明を照合。実モデルの過去の正解数・費用・時間は独立再測定していません。

対象と検証条件

公開コードは下記コミットに固定。Linux / Python 3.12.14 / Node 24.22.1で検証し、pytest・Flask・OpenAI SDKはリポジトリの指定版を使用しました。CIのPython 3.13 / Node 22と実行環境は異なります。公開デモがこのコミットと同一のビルドかは未確認です。

1b7e7bde1c0e9f0d437f9c36fbb395e0b39f9a07
https://role-assistants-662084666675.us-central1.run.app

追加検証は架空データとモデルのスタブ応答を使ったローカル検証です。本番に対する異常系試行や実在データの入力、ソース・設定の変更はしていません。これは対象範囲を限定した技術レビューです。

説明と実装の一致 / 計測値の扱い

説明	確認結果・留保
AIがルール判定を下げない	rules.combine_statusは順位の最大値を選択。モデルがclearでもルール側のblocked等が残り、既存テストも成功。
改ざん結果・未承認の次工程を拒否	HMACでplan / ticket / receiptを検証。価格改ざんや別runへのreceipt流用の拒否テストがある。ただし企業・版との紐付けはH01参照。
禁止スキルをアシスタントから除外	生成済みkitからの除外、子階層の禁止維持は確認。固定注文ワークフローの実行時には禁止を再確認していない（H03）。
チャットをサーバー保存しない	メッセージ用DBテーブルなし。既存テストでDB・ログ不変を確認。手渡した業務書類は別途保存する設計で、チャット非保存と区別される。
Privateは標準モデルへ黙って戻らない	コード・スタブ試験に代替呼出し防止あり。今回の正常経路ではGlimmerの応答をUIで確認。障害やコールドスタートは本番で再試験していない。
計測の限界を明示	小規模・合成データ、作者作成の採点、未測定の利用者効果、set14の再実行不可等がREADMEとMEASUREDに記載されている。

測定結果をどこまで確認したか

set11の20ケースはコードから読み出し、ルールだけでは全20件がclearになることを独立確認しました。したがって矛盾検知をモデル層の評価とする試験構成は妥当です。ただし「Spark 10/10」「Glimmer 9/10」等は作者の過去測定結果であり、今回の403件のスタブ試験がその精度を実証するわけではありません。

公開ツリーでは主要な実モデル測定セットの個別応答・生の実行結果を確認できません。実モデル用のキー・課金を用いた一括再測定は実施していないため、過去のコスト・待ち時間・正解数を独立認証したとは扱えません。set14が報告のみで再実行不可である点は、既に明記されています。

> L01 / 軽微：medianの定義を統一してください。
> measure.pyの複数箇所は sorted(values)[len(values)//2] を使用。偶数件では通常の中央値（中央2値の平均）ではなく上側中央値です。例：1〜10なら6、通常の中央値は5.5。statistics.medianへ統一するか、upper medianと明記し、生データから再集計してください。

根拠：scripts/measure.py L107

根拠：docs/MEASURED.md

根拠：tests/test_workflow.py

H01 署名済み計画が企業に紐付かない

> 優先度：高 / ローカルHTTP再現済み
> 正規の署名を持つ企業Aの計画を企業Bの利用者で実行すると、Bの緩いルールで処理できます。Aで発行された結果の承認もBの利用者で成功しました。

再現結果

条件	実際の応答
Aのマージン下限30%、Bは12%	同じAの署名済み計画・同じ注文を使用。
Aの利用者で /api/workflow/step	HTTP 200 / needs_attention
Bの利用者で同じAの計画を実行	HTTP 200 / clear
BがAのticketを /api/workflow/approve	HTTP 200 / receipt発行
関連：組織図を置換した後の旧計画	旧ロールを組織図から除いた後も旧ticketの承認がHTTP 200。

原因：署名対象はkind・run_id・step_id・payloadで、planに企業IDや会社・ポリシー版、操作主体が入りません。stepはリクエストに付いた利用者の企業からルールを取得し、approveは利用者が有効かを確認した後、その企業・ロールを使用していません。

影響範囲：Aの署名済みplan / ticketを既に持つことが前提です。他社の未知の注文を一覧取得できる、トークンを推測できる、署名を暗号的に偽造できると確認したものではありません。署名自体が破られたのではなく、正規署名の利用範囲を拘束していない問題です。

修正と合格条件

plan・ticket・receiptに同一の企業ID、会社 / ポリシー版、有効期限を結び付け、全エンドポイントで現在の利用者と照合してください。操作主体も必要な範囲で不透明なIDに結び付け、担当者別承認か単一利用者によるデモ承認かを仕様として明示します。

合格条件：Aの計画・結果・receiptをBで使う全経路を拒否し、会社・ルール変更後の旧計画を失効させるか、現在の権限とルールで再評価します。通常の同一企業内の一連の承認は引き続き成功することを確認します。

根拠：app.py L333

根拠：workflow.py L57

H02 計算引数が元の注文と一致しない

> 優先度：高 / モデルスタブで再現済み
> 計算式はコードですが、妥当な型・範囲の誤った引数をAIが選ぶと、そのまま計算・署名・承認できます。元注文と計算入力の一致をコードで保証していません。

検証例	期待 / 実際
10パレットの署名済み注文	期待：10 × レート → price 1,800 / cost 1,500。
AIが有効な引数 pallets=1 を選択	実際：price 180 / cost 150。clear、demo_mode=false、承認receiptも発行。
Financeが price=10000, cost=1 を選択	署名済み見積は1,800 / 1,500なのに、Finance結果は10,000 / 1、margin 100.0%となりclear。

原因：call_toolは期待するツール名と引数の型・範囲を検査しますが、署名済みtask / 前段receiptと各引数を照合しません。入力として有効な別数量・別金額はエラーにならず、再試行・元データへの切替も起きません。後段のモデルチェックが見逃すとclearになります。

確認の意味：これは実モデルが今回の頻度で誤るという測定ではありません。モデルが誤った有効引数を返した場合に、コードの安全境界が防げないことを示す試験です。今回の本番1注文の価格・原価・マージンは正しく計算されました。

修正と合格条件

quote_priceのroute / palletsは署名済み注文に、check_marginのprice / costは署名済み見積に、calendarの日付は署名済み注文に一致させます。業務上変更を認める場合は、変更案として差分を示し、元注文の改訂を人が承認してから再計画します。

不一致時はその結果を実行・clear扱いにせず、引数を正規化して再確認するか、明示的なエラー / 要確認へ移してください。テストには「無効な引数」だけでなく「有効だが注文と異なる引数」を含めます。

データを結び付けてから署名する

署名は、サーバーが作った結果の改ざんを検知します。サーバー自身が誤った入力から作った結果の正しさまでは保証しません。READMEの「every number is plain code」という説明には、元データ拘束の有無を併記すべきです。

根拠：workflow.py L113

根拠：workflow.py L214

根拠：tools.py

H03 禁止済みスキルが注文経路で実行される

> 優先度：高 / ローカルHTTP再現済み
> Groupでquote_priceを禁止すると、Salesのkitからは除かれます。しかし禁止後に新規作成した注文計画でも、quote_priceが実行されます。

操作 / 検査	結果
Groupで banned_skills=[quote_price] を保存	HTTP 200
Sales kitのskillsを取得	quote_priceは含まれない。除外処理自体は成功。
禁止後に新規planを作成しquoteを実行	HTTP 200 / tool=quote_price / price=1800

原因：固定のSTEPSとhandoff辺は検証されますが、ツール実行前に現在の企業の禁止一覧・役割の許可スキルを照合しません。これは旧計画だけの問題ではなく、禁止後の新計画でも再現します。

修正と合格条件

各ツール呼出しの直前に、役割の許可一覧と全階層の禁止一覧をサーバーで確認してください。禁止があればモデルを呼ばず、ツールも実行せず、拒否理由を返します。plan発行時と承認時にも同じ制約を確認し、途中の禁止変更が通り抜けないようにします。

合格条件：新規計画・既存計画・直APIのすべてで禁止ツールを拒否。禁止していない正当なツールは引き続き動作し、子階層で親の禁止を解除できない既存テストも維持します。

根拠：app.py L503

根拠：workflow.py L18

根拠：workflow.py L214

根拠：rules.py L99

「署名付き承認」という説明の精度

実装は利用者本人の秘密鍵による電子署名ではなく、Approve操作を受けたサーバーがHMAC保護したreceiptを発行する方式です。物流の3段階デモは同じ招待利用者がすべて承認します。Inboxのmaker-checker・役割別判断とは別の経路として説明してください。本人の否認防止や、各担当者が個別に署名した監査記録があるとは言えません。

> 表現例：After a person clicks Approve, the server issues an HMAC-protected receipt for the approved result.
> 修正後は、そのreceiptが企業・版・操作主体にも結び付くことを説明します。

本番での留意点と修正後の確認項目

M01 / 中：Clearと矛盾指摘の併記を本番で観測

今回のFinanceステップは、price 2,160 / cost 1,800 / margin 16.7%を正しく表示しました。一方、状態はClearなのに、説明とAssistant's notesには「マージンが価格・原価と一致しない」と表示されました。そのまま最終承認・注文完了までは成功しています。モデル応答の実測は1件で、発生率は未測定です。

状態と説明が食い違う場合はClearのまま見せず、矛盾を明示して要確認にするなど、保守的な整合性処理を設けてください。モデルがclearと不整合所見を同時に返すスタブ応答を追加し、画面・最終状態が一致することを検証します。

優先	修正後に必ず確認すること
1 / H01	別企業のplan・ticket・receiptを拒否。会社・ルール版変更後の旧計画の扱いを固定。
2 / H02	元注文と異なる有効な数量・金額・日付を検知し、誤った入力のまま署名・承認しない。
3 / H03	禁止スキルは新旧計画と直APIの全経路で実行されず、モデル呼出し前に停止。
4 / M01	Clearと矛盾所見を併記しない。ステータス・説明・確認操作を一致させる。
5 / L01	中央値を通常定義に統一し、個別の計測出力と版を残して再集計。
回帰確認	既存403件・JS33件に境界テストを追加。最後に公開デモを1注文通し、画面とREADMEを再照合。

計測資料をさらに検証可能にする最小構成

主要セットの匿名化した個別JSON、実行時刻、コードSHA、モデルID、設定、集計スクリプトを一緒に残してください。成功件数だけでなく失敗・タイムアウト・無回答を含め、31.9秒等の過去の単発値と今後の再測定値を混ぜずに表記します。個人情報やキーを公開する必要はありません。

最終所見

企画の意図と通常デモは成立しています。説明の誠実さにも強みがあります。改善の中心は機能追加ではなく、元データ・企業・許可と署名済み結果を一貫して結び付けることです。上の3点を直すまでは「企業の権限と制約を実行まで保証する完成品」との評価は留保します。

本レポートの再現結果は指定コミットのローカル環境で取得。本番では正常経路と表示の確認のみを実施。音声・写真・全業種・並行処理・負荷耐性・第三者調査出典の再検証は今回の範囲外です。

根拠：README.md

根拠：static/join.js L283